

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 3 Practical Laboratory

Roles, Responsibilities and Accountability in Security
Governance

TechGlobal Governance Transformation Simulation

Student Information	
Full Name	Khodani Netshifhefhe
Registration Number	C11/26/CGRCE/17580
Email Address	c11.cgrce2617580@icdfa.edu.ng
Submission Date	25 September 2026

Task 1 Governance Architecture and Stakeholder Map (20 marks)

Required Evidence Task 1

Governance gap assessment

Weakness	Business or risk consequence
Most security decisions are still concentrated with the IT Director	IT Directory holds ownership, approval and operation of security at once, with no independent check. This creates a single point of failure and lets delivery pressure override risk judgement.
There is no formal governance committee structure	Other business Units such as Finance and HR are left out of security decisions. Trade-offs are made ad hoc, funding isn't prioritised by risk, and decisions aren't documented or defensible if challenged later.
Business units operate inconsistently	Control strength varies by office, so attackers target the weakest site and risk cannot be compared or aggregated across the organisation.
The CEO and Board receive limited visibility into cyber risk	Risk appetite is never actually set or tested, and directors cannot discharge their oversight duty. This raises accountability exposure and the chance of reputational or regulatory damage after an incident.
No formal escalation path	Material risks stay buried at operational level. Incidents reach leadership late, which risks missed regulatory deadlines such as the 72-hour notification under GDPR Article 33.

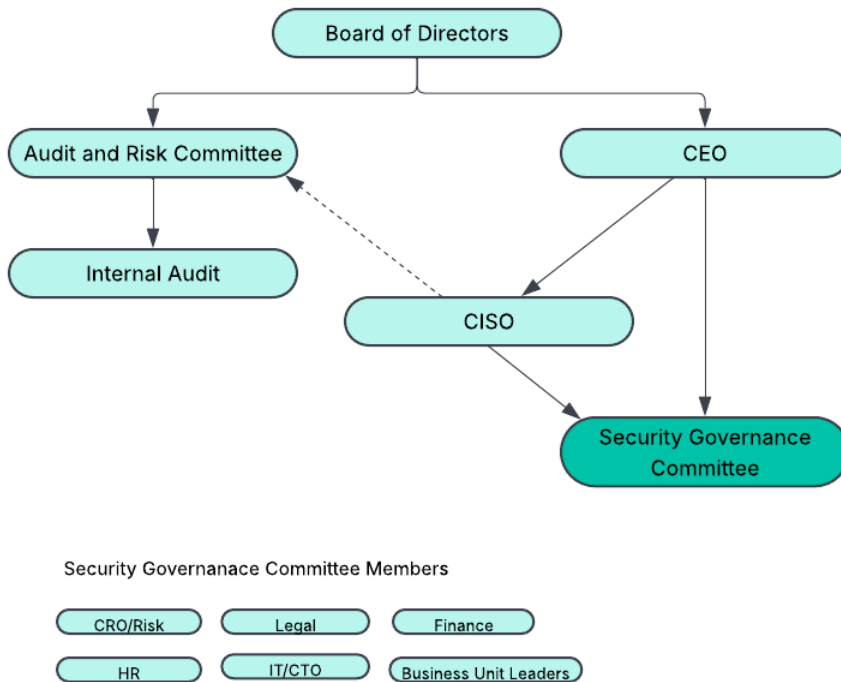
Stakeholder Map

Stakeholder	Authority/Influence	Primary Interests	Information Needs	Governance Contribution
Board	Final oversight and approval of the	Security Assurance, Regulatory	Quarterly risk dashboard, major	They set appetite, challenges

	company's risk appetite	exposure and reputation.	incidents, and assurance results	management, and oversee accountability
CEO	They have the executive accountability and they accept risk at a business Unit level	Company growth, strategic fit and acceptable risk	Top risks reports, summarized incident impact and compliance programme status	Enforces accountability and chairs committee meetings
CISO	Owns security strategy, policy and reporting	Risk reduction and programme effectiveness	Threat, control and incident data across all units	Sets policy and standards, leads the committee, and reports to the Board
CRO/Risk	Owns risk methodology and the risk register	Consistent, aggregated enterprise risk	Risk ratings, Risk treatment plans, and Risk acceptances	Integrating cyber risk into business risk and challenges risk acceptance
Legal	Advises on legal duty	Regulatory duty, third party relations, and privacy	Incidents, data-impact facts, regulator changes	Advice, and evidence preservation
Finance	Controls budget and funding approval	Loss exposure, investment priorities	Cost of controls, loss estimates, risk-versus-cost data	Funds security by prioritizing risk, and validates loss figures
HR	Owns people processes	Employee controls both joiner, mover, or leaver code of conduct	Access change events, awareness results, policy breaches	Onboarding and offboarding controls, awareness, disciplinary process

IT	Onboarding and offboarding controls, awareness, disciplinary process	Business service continuity and secure implementation	Standards, requirements and vulnerability priorities	Implements and operates controls; reports control status
Business Units	Own local risk and control implementation	Performance, local risk decisions	Policy, risk ratings, control duties	Act as risk owners, apply standards and escalate risks

Security Governance Organisation Chart



By Khodani Netshifhefhe

Consultant justification

Why does the current model have to change?

The size of TechGlobal no longer supports decision-making by one person. With 2,500 staff and five offices, the IT Director cannot own security, approve risk, and run operations at once without conflicts. Bringing in other departments like Legal, Finance, HR and the business units is what turns security from an IT task into a business decision.

The new structure gives oversight

The Board sets risk appetite through its Audit and Risk Committee, and they then receive independent assurance from Internal Audit. This gives directors the visibility they lack today and supports the leadership expectations set out in ISO/IEC 27001, which requires top management to demonstrate leadership and commitment to the information security management system and to integrate its requirements into business processes (ISO, 2022, clauses 5.1, 5.3). It also aligns with COBIT 2019's governance objectives for ensuring governance framework setting and maintenance, and for ensuring benefits delivery through Board-level oversight (ISACA, 2018, EDM01, EDM03).

It also supports independence

The CISO reports to the CEO rather than to IT, so the person who owns security strategy no longer answers to the function whose systems are being assessed. The CISO also has a dashed line to the Board committee. That way a serious risk cannot be filtered out on its way up.

Helps with cross-functional decisions

The Security Governance Committee, chaired by the CEO or a delegate, brings all functions into one forum. Risk methodology sits with the CRO, notification advice with Legal informed by statutory duties such as the 72-hour breach notification requirement under the GDPR (EU, 2016, Art. 33), funding with Finance, and joiner, mover, and leaver controls with HR. IT keeps technical delivery, but it no longer approves the risks it creates.

Local ownership

Business unit leaders remain risk owners for their areas, but they follow common standards and must escalate above a set threshold.

Why it fits a 2 500 employee, five-office technology company

The company is too large for informal decisions but not large enough to justify layers of regional administration. One committee and three clear reporting lines; oversight, executive, operational keep decisions quick while giving real accountability. For the five offices, I recommend a named security champion in each, reporting to the CISO through a dotted line.

Task 2 Governance Responsibility and Authority Matrix (20 marks)

Required Evidence Task 2

Cross-functional Governance Responsibility Matrix.

Role	Purpose	Core Responsibilities	Decision Authority	Reports / Escalates To	KPIs / Evidence
Board	Provide independent oversight of cyber risk and hold management accountable	Approve risk appetite, review material risk, and commission independent assurance	Final sign off on risk appetite	Receives reports from CEO or CISO and Internal Audit directly	Material risks reviewed within one board cycle and percentage of audit findings closed on time
CEO	Own overall accountability for the security programme and its business alignment	Sponsor Security Governance Committee, accepts risk within Board set limits and resources the CISO	Approves strategy and budget, accepts risk up to a certain limit and resolves cross functional disputes	Reports to the Board quarterly and immediately on material incidents	Time from incident detection to Board notification as well as the percentage of committee decisions that get implemented on schedule
CISO	Leads security strategy, policy and risk management	Sets policies and standards. They run Security Governance Committee agenda and escalate material risk.	Approves security controls and approves exceptions below CEO threshold	Reports to CEO and direct escalation line to Audit & Risk Committee	Mean time to remediate critical vulnerabilities and percentage of business units meeting control baselines
CRO / Risk	Integrate cyber risk into enterprise risk management	Owns risk register, validate risk ratings and challenge risk acceptances	Approves risk rating criteria and they are accountable for aggregated register	Reports to CEO and Board, consults Legal/Finance on treatment	Total percentage of risks with current treatment plan, and rating variance (self-assessed vs. validated)
Legal	Ensures that legal and regulatory obligations are met on data and incidents	Advise on regulatory duty, and own breach notification decisions they also oversee that evidence is being handled according to proper chain of custody	Final, non-overridable sign-off on notification decision and timing	Reports to CEO and Security Governance Committee	Percentage of notifiable incidents reported within statutory deadline and contracts reviewed for security clauses

Finance	Ensure security investment is funded, justified and controlled	Approve/track budget, quantify loss exposure and validate cost-benefit of controls	Approves budget allocation within CEO limits, also accountable for financial control of spend	Reports spend/loss data to Security Governance Committee	Budget variance, and yearly loss exposure trend
HR	Govern people-related controls that reduce insider/access risk	Own joiner, mover, and leaver processes. They run awareness/conduct programmes, and manage disciplinary process	Sign-off on access-related HR process design and accountable for awareness completion	Reports completion rates/exceptions to Security Governance Committee	Percentage of leavers with access revoked in under 24hrs, successful joiner/leaver onboarding as well as awareness completion rate
IT	Deliver and operate the technical environment securely	Implement approved controls, maintain continuity and report control status	Accountable for operations within CISO standards, with no authority to approve their own risk exceptions	Reports control status/incidents to the CISO	Patch and vulnerability closure rate vs SLA. System uptime vs targeted uptime

Role profiles / responsibility cards for the eight core governance roles.

BOARD OF DIRECTORS

- **Purpose:** Provide independent oversight of cyber risk and hold executive management accountable for the security programme.
- **Key governance responsibilities:** Approve the overall risk appetite; review material risk and incident reports; commission independent assurance through Internal Audit.
- **Decision authority:** Final sign-off on the risk appetite statement; approves CISO appointment or removal on the CEO's recommendation.
- **Reporting obligations:** Receives a quarterly cyber risk report from the CEO/CISO, and receives Internal Audit findings directly, independent of management.
- **Performance indicators:** Number of material risks reviewed within one Board cycle of escalation and percentage of audit findings closed within agreed timeframes.

CEO

- **Purpose:** Own overall executive accountability for the security programme and ensure it is aligned to business strategy.

- **Key governance responsibilities:** Sponsor and chair (or delegate chairing of) the Security Governance Committee; ensure the CISO has sufficient authority and resourcing; accept risk within delegated limits.
- **Decision authority:** Approves security strategy and budget; accepts risk up to the Board-set threshold; resolves cross-functional disputes not settled at committee level.
- **Reporting obligations:** Reports to the Board quarterly, and immediately upon any material incident.
- **Performance indicators:** Time elapsed from incident detection to Board notification and percentage of Security Governance Committee decisions implemented on schedule.

CISO

- **Purpose:** Lead security governance, strategy and policy, and report on programme effectiveness.
- **Key governance responsibilities:** Set security policy and standards; lead the technical agenda of the Security Governance Committee; escalate material or contested risk.
- **Decision authority:** Approves security architecture and control design; approves risk exceptions below the CEO's risk-acceptance threshold; cannot approve deviations that exceed that threshold.
- **Reporting obligations:** Reports to the CEO on programme performance; holds a direct escalation line to the Audit & Risk Committee for material risk, independent of the CEO.
- **Performance indicators:** Mean time to remediate critical vulnerabilities and percentage of business units meeting the minimum control baseline.

CRO / RISK

- **Purpose:** Integrate cyber risk into enterprise risk management and maintain a consistent risk methodology.

- **Key governance responsibilities:** Own and maintain the enterprise risk register; validate risk ratings submitted by business units and the CISO; challenge proposed risk acceptances.
- **Decision authority:** Approves the risk rating methodology and criteria; accountable for the accuracy of the aggregated risk register.
- **Reporting obligations:** Reports enterprise risk posture to the CEO and Board; consults Legal and Finance on treatment options.
- **Performance indicators:** Percentage of risks with a documented, current treatment plan and Variance between business-unit self-assessed ratings and validated ratings.

LEGAL / COMPLIANCE

- **Purpose:** Ensure the organisation meets its legal and regulatory obligations relating to data and security incidents.
- **Key governance responsibilities:** Advise on regulatory duties and contractual obligations; own breach notification decisions; oversee evidence preservation.
- **Decision authority:** Final, non-overridable sign-off on whether and when a breach is notified to regulators or affected individuals.
- **Reporting obligations:** Reports regulatory exposure and incident-related legal risk to the CEO and Security Governance Committee.
- **Performance indicators:** Percentage of notifiable incidents reported within statutory deadlines and number of contracts reviewed for security clauses prior to signature.

FINANCE

- **Purpose:** Ensure security investment is adequately funded, justified and financially controlled.
- **Key governance responsibilities:** Approve and track the security budget; quantify potential loss exposure; validate the cost-benefit of proposed controls.
- **Decision authority:** Approves budget allocation within limits set by the CEO; accountable for financial control over security spend.

- **Reporting obligations:** Reports spend and loss-exposure data to the Security Governance Committee.
- **Performance indicators:** Budget variance against approved security spend and yearly trend in estimated loss exposure.

HR

- **Purpose:** Govern the people-related controls that reduce insider risk and access-related exposure.
- **Key governance responsibilities:** Own joiner/mover/leaver processes; run the security awareness and conduct programme; manage disciplinary process for policy breaches.
- **Decision authority:** Final sign-off on the design of access-related HR processes; accountable for awareness programme completion.
- **Reporting obligations:** Reports completion rates and process exceptions to the Security Governance Committee.
- **Performance indicators:** Percentage of leavers with access revoked within 24 hours and security awareness training completion rate.

IT

- **Purpose:** Deliver and operate the technical environment securely and reliably.
- **Key governance responsibilities:** Implement controls approved by the CISO; maintain service continuity; report technical control status.
- **Decision authority:** Accountable for day-to-day technical operations within CISO-approved standards; **has no authority to approve exceptions to its own risk** — exceptions must be escalated to the CISO.
- **Reporting obligations:** Reports control status and incidents to the CISO.
- **Performance indicators:** Patch and vulnerability closure rate against SLA as well as system uptime.

Short conflict-resolution note identifying overlapping authority and resolution principles.

IT versus CISO for control exceptions

IT wants flexibility, like delaying a patch. The CISO wants standards to be enforced.

Resolution - IT implements but cannot approve its own exceptions. Any changes must be escalated to the CISO for sign-off.

CISO versus CRO/Risk regarding risk rating

Technical severity (CISO) and enterprise impact (CRO) may disagree.

Resolution - CRO owns the final rating under the enterprise's methodology whilst the CISO supplies technical input. Unresolved disputes go to the Security Governance Committee, then the CEO.

Legal versus CEO/business on breach notification timing

The business may want to delay notifying on the breach. Legal has a statutory deadline as 72 hours under GDPR Art. 33.

Resolution - Legal holds final, non-overridable sign-off on notification.

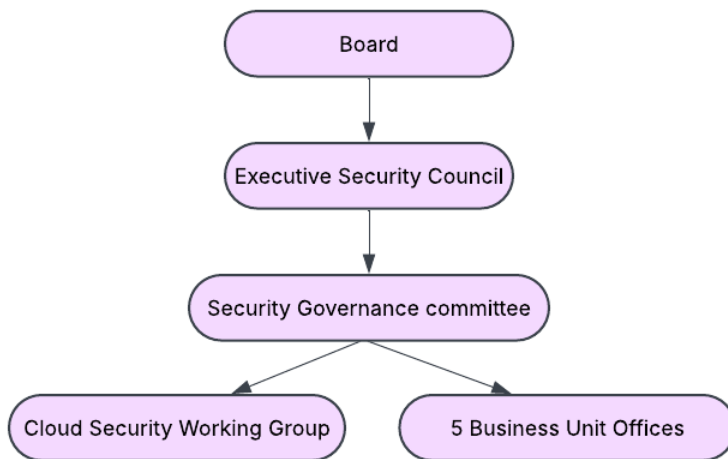
Principle

No function should approve exceptions to a standard it must also follow. Conflicts escalate to the Committee then the CEO, except legal or assurance duties (Legal, Internal Audit) that management cannot override.

Task 3 Security Governance Committee Ecosystem (20 marks)

Required Evidence Task 3

Committee structure / interaction diagram.



Terms of Reference for the Security Governance Committee

Purpose

Provide the cross-functional forum where security risk, investment and compliance decisions are reviewed and resolved collectively, coordinating input from working groups and business units before escalating material matters to the Executive Security Council.

Chair: CISO

Secretary: Rotates among members and minutes are retained centrally.

Membership: CISO (chair), CRO/Risk, Legal, Finance, HR, IT, and one Business Unit Offices.

Frequency: Takes place monthly, with an ad hoc session triggered within 5 business days of a material incident.

Quorum: CISO and at least four other members, including at least one 5 business unit group.

Scope of authority

- Approves security policy and standards below Board/CEO level.
- Reviews and prioritises the risk register for escalation.

- Approves working-group charters and reviews their output.
- Recommends budget priorities to Finance and the Executive Security Council.
- Cannot itself accept material risk that authority sits with the CEO/Board.

Reporting

Minutes and a risk summary go to the Executive Security Council after every meeting and material items are flagged for escalation using the criteria in the decision-flow section below.

Review

These Terms of Reference are reviewed annually or after any material governance failure.

Sample committee agenda

Security Governance Committee Monthly Meeting

1. Minutes and actions from previous meeting – Chair (5 min)
2. Risk register review new and changed risks – CRO (20 min)
3. Cloud Security Working Group update – Chair (15 min)
4. Incident summary for the past 30 days - IT (10 min)
5. Business unit compliance status – BU group updates (15 min)
6. Budget/investment requests for recommendation - Finance (15 min)
7. Items for escalation to Executive Security Council - Chair (10 min)
8. Closing and next meeting date – Chair (5 min)

Sample decision log with at least three example decision entries

Date	Decision	Raised by	Authority used	Outcome
2026-09-01	Approve migration of customer database to encrypted cloud storage with quarterly key rotation	Cloud Security Working Group	Committee approval (below CEO risk threshold)	Approved IT to implement within 60 days

2026-09-10	Decline IT's request to exempt Office 4's legacy applications from MFA	IT	Committee declined no authority to approve exception to a standard IT must also follow.	IT directed to onboard the legacy application within 6 months instead
2026-09-13	Approve updated third-party vendor security questionnaire as mandatory pre-contract step	Legal	Committee approved	Approved

12-month governance calendar showing recurring governance activities and key milestones.

Month	Recurring governance activities	Key Milestones
January	Security Governance Committee (monthly) and Cloud Security Working Group update	Annual risk appetite statement reviewed by Board
February	Security Governance Committee and Business Units liaison compliance round table	Internal Audit annual plan approved
March	Security Governance Committee; Executive Security Council (quarterly)	Q1 cyber risk report to Board
April	Security Governance Committee and working Group update	Annual security policy review and sign-off
May	Security Governance Committee and business Units offices round table	Third-party/vendor risk review cycle begins

June	Security Governance Committee and Executive Security Council (quarterly)	Q2 cyber risk report to Board and mid-year budget review
July	Security Governance Committee and Working Group update	Security awareness campaign refresh (HR)
August	Security Governance Committee and Offices Business Units round table	Internal Audit mid-year findings review
September	Security Governance Committee and Executive Security Council (quarterly)	Q3 cyber risk report to Board and roles review
October	Security Governance Committee and Working Group update	Business continuity and incident response tabletop exercise
November	Security Governance Committee and Offices Business Units round table	Budget planning for next fiscal year
December	Security Governance Committee and Executive Security Council (quarterly)	Q4 cyber risk report to Board and annual governance model effectiveness review

Task 4 RACI Accountability Matrix (20 marks)

Required Evidence Task 4

Completed TechGlobal RACI Matrix

R- Responsible A-Accountable C-Consulted I-Informed

Activity	Board	CEO	CISO	CRO/Risk	Legal	Finance	HR	IT	BU Leader
Cybersecurity strategy approval	C	A	R	C	I	C	I	I	I
Security policy approval	I	A	R	C	C	I	I	C	I
Enterprise cyber-risk assessment	I	I	C	A/R	I	I	I	C	C
Risk acceptance	C	A	R	C	C	I	I	I	I

Security budget approval	I	A	R	I	I	R	I	C	I
Security architecture approval	I	I	A/R	C	I	I	I	C	I
Third-party security review	I	I	A	C	C	C	I	R	C
Access governance	I	I	C	I	I	I	A	R	C
Incident response governance	I	C	A/R	C	C	I	I	R	C
Material incident escalation	I	A	R	C	C	I	I	R	C
Regulatory notification decision	I	I	C	I	A/R	I	I	I	I
Security awareness programme	I	I	C	I	I	I	A/R	C	C
Vulnerability remediation oversight	I	I	A	I	I	I	I	R	C
Business continuity / recovery governance	I	A	C	C	C	C	C	R	R
Board cyber-risk reporting	A	R	R	C	C	I	I	I	I

One-page implementation guide explaining how managers should use the RACI matrix during planning, approvals and incidents.

Purpose

This RACI matrix tells every manager, before a decision or incident happens, who they need in the room and who has final say so that no one has to work it out under time pressure.

During planning

- The first ownership we have to before working towards a security related decision check the Accountable column first that's the one sign-off we need before anything continues.
- Anyone marked Consulted must be engaged *before* the decision is finalised, not informed after the the decision.
- Treat a missed Consulted party as a process failure, not an oversight to fix later.
- If an activity shows the same role as both Accountable and Responsible, managers should proactively bring in the suggested secondary check rather than treating the single-role approval as sufficient.

During approvals

- Only the Accountable role can approve.
- A Responsible party doing good work does not automatically qualify for Accountable sign-off
- Where Finance or Legal hold Accountable status (budget, notification), other stakeholders including the CEO cannot override that sign-off through seniority alone, escalation can be sent to the board instead.

During incidents

- Incident Escalation and Incident Response Governance are important to know before an incident happens, not during one.
- The CEO is accountable for escalation decisions.
- The CISO is accountable for the response itself, with IT executing technical containment. If a manager is unsure who's in charge in the first ten minutes, the answer is: CISO for the technical response, CEO for anything that needs to be reported outward.
- Legal is Accountable for the regulatory notification decision alone no other role.

Task 5 Cyber-Risk Escalation and Segregation of Duties (20 marks)

Required Evidence Task 5

Major Cyber-Risk Escalation Workflow

Step 1: Operational detection or identification

An issue is identified by IT, a monitoring tool, a business unit, or a third party.

Step 2: Triage and initial rating

IT assesses severity and assigns an initial level.

Step 3: Level 1 - Operational

IT handles and logs the issue within CISO-approved standards. If resolved within scope, it is logged and closed.

Step 4: Escalation trigger check

Does the issue exceed IT's own operational authority, involve cross-functional impact, or repeat unresolved?

Step 5: Level 2 - Executive

CISO and CEO, via the Security Governance Committee / Executive Security Council, review and decide. If resolved within scope, it is logged and closed.

Step 6: Escalation trigger check

Does the issue exceed the CEO's risk-acceptance threshold, or carry regulatory, financial or reputational materiality?

Step 7: Level 3 - Material / Board

The Board / Audit & Risk Committee, on the Executive Security Council's recommendation, makes the final decision to accept, defer, or treat.

Step 8: Decision recording

Every decision at every level is recorded in the central decision log with owner, rationale, and target closure date.

Escalation threshold table

Level	Example Trigger	Decision Authority	Required Notification	Target Response Time
Level 1 – Operational	Regular exposure to risk, one piece of malicious software identified, one unusual user access pattern	IT or CISO delegate	Logged in incident system; CISO informed via weekly summary	24 hours to triage and 5 business days to close
Level 2 – Executive	Multi-system compromise Repeat unresolved Level 1 issue Third-party breach affecting TechGlobal data Risk above CISO approval limit	CISO and CEO	CEO notified within 4 hours; Committee briefed at next session or ad hoc if urgent	24 hours to executive decision
Level 3 – Material / Board	Confirmed data breach including customer data, national-media-risk incident and threat to business continuity across multiple offices	Board or Audit & Risk Committee	Board notified within 24 hours and Legal assesses regulatory notification duty in parallel	Board decision within 48 hours and regulatory deadline governs were shorter

Segregation-of-Duties / Accountability Weakness Register with at least five issues and recommended controls.

ID	Process Area	Weakness / Conflict	Risk Created	Roles Involved	Recommended Control	Residual Risk / Review
1	Change & risk approval	IT Director designs, implements and approves security controls	No independent check and risk decisions favor delivery speed	IT	Require CISO sign-off on control design separate from IT's implementation role	Low
2	Access management	IT provisions and reviews its own privileged access	Self-review of admin access enables undetected misuse	IT	Quarterly independent access review by HR or CISO jointly; automated	Low

					privileged-access logging	
3	Risk assessment & validation	CRO produces and validates the enterprise risk assessment	No independent challenge of the CRO's own output	CRO/Risk	Annual Internal Audit review of risk assessment methodology and outputs	Medium
4	Incident response command	CISO is both accountable for and executes incident response decisions	Ambiguity over final call during live incidents and delay risk	CISO, IT	Formal Incident Commander role in the IR plan, distinct from ongoing CISO policy accountability	Low
5	Vendor/third-party approval	IT can select and approve third-party tools without independent security review	Unvetted vendors introduce unmanaged risk	IT, Procurement	Mandatory third-party security questionnaire before contract	Low

Short decision-recording and assurance note.

Escalations at any of the three levels are recorded in the central decision log which includes date, decision, trigger level, decision authority, rationale and target closure date. This is not optional documentation, this is what makes the escalation model auditable instead of theoretical.

Recording

It is also worth mentioning that the originating forum (IT, CISO delegate, Security Governance Committee or Board) records the decision when the choice is made, not in hindsight, thus the trail indicates what was actually understood at the time.

Tracking

Each entry has an owner and is either open or closed. The Security Governance Committee has open issues as a standing agenda item that it reviews monthly; issues that remain open past their target closure date are immediately flagged as a re-escalation.

Review

In accordance with the annual audit plan outlined in the governance calendar, Internal Audit will periodically sample the decision log to verify that decisions are being made at the appropriate level of authority and within target response times.

Closure

A decision is not deemed closed until the control or action agreed upon has been verified to have been executed, not simply approved. Technical elements are to be verified by the CISO, all others by the original Accountable position.

References

1. European Union. (2016). Regulation (EU) 2016/679 (General Data Protection Regulation), Article 33.
2. International Organization for Standardization. (2022). Information security, cybersecurity and privacy protection Information security management systems Requirements (ISO/IEC 27001:2022).
3. ISACA. (2018). COBIT 2019 framework: Governance and management objectives. ISACA.